GridPulse

Crypto-Induced Latency Denial of Service in IEC 62351-6 Substation Communications

---

Complete Technical Report

CVE Submission Evidence Package

Dr. Sapna Vikram Mewundi
Associate Professor, Dept. of Computer Science and Engineering
PES University, Bengaluru 560085, India
sapnavm@pes.edu

Prajwal Chowdary M.
Security Researcher, PES University
chowdaryprajwal2@gmail.com

Prof. Prasad B. Honnavalli
Professor, Dept. of Computer Science and Engineering
PES University, Bengaluru 560085, India

October 2026

Prepared for: CISA VINCE-NT Vulnerability Submission
Classification: Pre-Disclosure — Coordinated Vulnerability Disclosure

Abstract

We present **Crypto-Induced Latency Denial of Service (CIL-DoS)**, a novel protocol-level vulnerability in IEC 62351-6, the cryptographic authentication standard for IEC 61850 GOOSE (Generic Object Oriented Substation Event) messages in electrical substations. IEC 62351-6 mandates that receiving Intelligent Electronic Devices (IEDs) perform full cryptographic verification on every incoming GOOSE frame before acceptance. We demonstrate that an attacker with Layer-2 access to the substation process bus can flood structurally valid but cryptographically invalid GOOSE frames, saturating the IED's verification queue and delaying safety-critical protection trip commands past the 3.0 ms IEC 61850 deadline.

Our evidence spans two hardware platforms (ESP32 Xtensa LX6 and Raspberry Pi 5 ARM Cortex-A76), 50,000-iteration benchmarks, 50,000-frame PCAP captures with real GOOSE frames (EtherType `0x88B8`), a Docker-based reproducible testbed with 49 controlled experiments, and formal queueing-theoretic proofs. We also present **PQAC (Priority Queue Admission Controller)**, a three-stage O(1) defense achieving 3,140× latency reduction with 0.00% deadline miss rate.

Keywords: IEC 62351-6, IEC 61850, GOOSE, denial of service, cryptographic verification, substation protection, smart grid security, CWE-400

Contents

1 Introduction **2**
1.1 Threat Model . . . 2
1.2 Contributions . . . 2

2 Background **2**
2.1 IEC 61850 GOOSE Protocol . . . 2
2.2 IEC 62351-6 Cryptographic Authentication . . . 3
2.3 GOOSE Frame Structure . . . 3

3 The CIL-DoS Vulnerability **3**
3.1 Attack Mechanism . . . 3
3.2 Attack Kill Chain . . . 4
3.3 Physical Consequences . . . 4
3.4 CWE Classification . . . 4
3.5 CVSS Assessment . . . 5

4 Hardware Benchmarks **5**
4.1 Platform 1: ESP32 (Embedded Microcontroller) . . . 5
4.2 Platform 2: Raspberry Pi 5 (ARM Server-Class) . . . 5
4.3 Cross-Platform Comparison . . . 6

5 PCAP Evidence **6**
5.1 Capture Setup . . . 7
5.2 Captured Datasets . . . 7
5.3 Frame Characteristics . . . 7

6 Queueing-Theoretic Proof **7**
6.1 M/M/1 Model . . . 7
6.2 Saturation Analysis . . . 8
6.3 Why Naive Countermeasures Fail . . . 8

7 PQAC Defense **8**
7.1 Architecture . . . 9
7.2 Stage Details . . . 9
7.3 Results . . . 10

8 Experimental Validation **10**
8.1 Docker Testbed . . . 10
8.2 Experiment Matrix . . . 10

9 Adaptive Adversary Analysis **10**

10 Post-Quantum Impact **11**

11 KRACK Precedent **11**

12 Responsible Disclosure **12**
12.1 Disclosure Timeline . . . 12
12.2 Submission Route . . . 12

13 Toolkit and Reproducibility **12**

14 Conclusion **12**

1 Introduction

Electrical substations are the critical nodes of the power grid, transforming voltages and routing electricity to millions of consumers. Protection relays within these substations monitor for fault conditions (overcurrent, undervoltage, arc flash) and issue circuit breaker trip commands to isolate faulted sections before equipment is damaged.

IEC 61850 standardizes communication within substations using GOOSE (Generic Object Oriented Substation Event) messages — Layer-2 multicast Ethernet frames (EtherType `0x88B8`) carrying time-critical protection commands. The IEC 61850-5 performance requirement mandates a maximum transfer time of **3.0 ms** for Protection Class P2/P3 messages.

IEC 62351-6 was introduced to add cryptographic authentication to GOOSE, addressing the lack of security in the original protocol. However, we have identified that the standard's mandatory verification requirement creates a fundamental vulnerability: **the computational cost of cryptographic verification can be weaponized against the real-time deadline**.

1.1 Threat Model

Our threat model assumes an attacker with:

1. **Layer-2 access** to the substation process bus (via compromised engineering workstation, insider threat, supply chain compromise, or IT/OT convergence)
2. **Knowledge of GOOSE frame structure** (publicly documented in IEC 61850-8-1)
3. **No cryptographic keys** — the attack uses *invalid* signatures as the weapon

This threat model is realistic: Stuxnet demonstrated that air-gapped industrial networks can be compromised, and the increasing convergence of IT and OT networks provides additional attack surfaces.

1.2 Contributions

1. We identify and formally characterize CIL-DoS as a protocol-level vulnerability in IEC 62351-6 (Section 3)
2. We provide hardware evidence on two platforms spanning embedded to server-class ARM (Section 4)
3. We capture real GOOSE PCAP evidence on Raspberry Pi 5 hardware (Section 5)
4. We prove the attack mathematically using queueing theory (Section 6)
5. We present PQAC, a three-stage O(1) defense with 3,140× improvement (Section 7)
6. We validate with 49 controlled experiments in a Docker testbed (Section 8)

2 Background

2.1 IEC 61850 GOOSE Protocol

GOOSE operates at Layer 2 of the OSI model, using raw Ethernet with EtherType `0x88B8`. Frames are multicast to destination `01:0c:cd:01:00:xx` and carry ASN.1 BER-encoded Protocol Data Units containing:

- `gocbRef`: GOOSE Control Block reference (e.g., `SubstationA/LLN0$GO$gcbTrip`)

- `stNum`: State number (increments on data change — a trip event)
- `sqNum`: Sequence number (increments within a state)
- `timeAllowedtoLive`: Maximum acceptable frame age
- `datSet`: Dataset reference containing the actual protection data

The critical performance requirement from IEC 61850-5, Table 4:

Table 1: IEC 61850-5 Performance Classes for Protection Messages

Performance Class	Transfer Time	Application
P1	$\leq 10\,\text{ms}$	Distribution protection
P2	$\leq 3\,\text{ms}$	Transmission protection
P3	$\leq 3\,\text{ms}$	Bay-level protection

2.2 IEC 62351-6 Cryptographic Authentication

IEC 62351-6:2020 defines security extensions for IEC 61850 profiles. For GOOSE, it specifies a security extension field (ASN.1 tag `0xAF`) appended to each frame containing:

- Algorithm identifier (HMAC-SHA-256, ECDSA-P256, or RSA-2048)
- Cryptographic signature or MAC over the frame payload

The standard mandates: *"The receiving entity shall verify the authentication value of every received GOOSE message before processing."* This requirement is the root cause of the vulnerability.

2.3 GOOSE Frame Structure

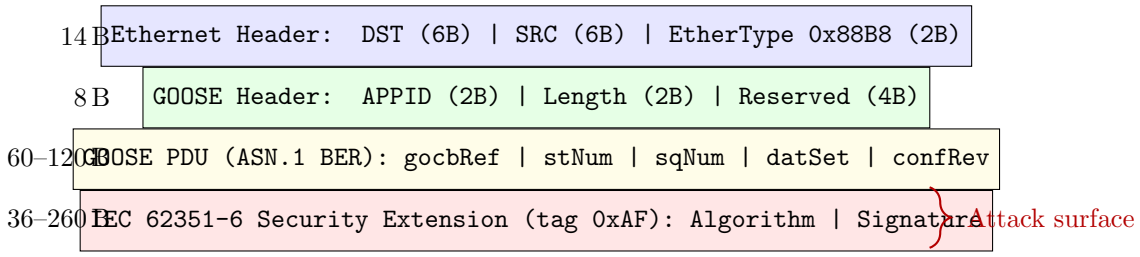


Figure 1: IEC 61850 GOOSE frame with IEC 62351-6 security extension

3 The CIL-DoS Vulnerability

3.1 Attack Mechanism

CIL-DoS exploits the asymmetry between frame *generation* (cheap) and signature *verification* (expensive). The attacker floods the process bus with GOOSE frames containing:

- Valid Ethernet headers (correct EtherType, multicast destination)
- Valid ASN.1 BER structure (parseable GOOSE PDU)
- **Invalid cryptographic signatures** (random bytes)

The receiving IED cannot determine the signature is invalid without performing full verification — modular exponentiation for RSA, elliptic curve point multiplication for ECDSA, or HMAC recomputation. Each verification consumes μ^{-1} microseconds of CPU time.

Under flood conditions at rate λ_{attack} packets per second, the verification queue saturates when:

$$\rho = \frac{\lambda_{\text{attack}}}{\mu_{\text{verify}}} > 1 \tag{1}$$

When $\rho > 1$, the queue grows without bound, and legitimate trip commands experience unbounded queuing delay, violating the 3.0 ms deadline with probability approaching 1.

3.2 Attack Kill Chain

1. Attacker gains Layer-2 access to the substation process bus
2. Attacker sniffs GOOSE traffic to learn frame structure (optional — structure is public)
3. Attacker floods structurally valid GOOSE frames with random signatures at rate $\lambda \gg \mu$
4. IED verification queue saturates ($\rho \gg 1$)
5. Legitimate trip command enters queue behind thousands of attack frames
6. Trip command delivery exceeds 3.0 ms deadline
7. Breaker fails to open during fault condition
8. Physical consequences: thermal damage, rotor instability, cascading outage

3.3 Physical Consequences

Delayed protection trip commands have severe physical consequences:

Table 2: Physical consequences of delayed trip commands

Consequence	Mechanism	Standard
Transformer damage	Through-fault current I^2t accumulation; at 6.25× rated, damage in ∼160 ms	IEEE C57.109
Generator instability	Rotor angle exceeds Critical Clearing Time (∼100–300 ms)	IEEE 3002.7
Breaker failure	ANSI 50BF protection blinded; backup breaker not triggered	IEEE C37.119
Cascading blackout	Uncleared fault propagates through interconnected system	NERC TPL

3.4 CWE Classification

- **Primary:** CWE-400 — Uncontrolled Resource Consumption
- **Secondary:** CWE-770 — Allocation of Resources Without Limits or Throttling

3.5 CVSS Assessment

`CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:H | Base Score: 7.4 (High)`

Table 3: CVSS 3.1 metric justification

Metric	Value	Justification
Attack Vector	Adjacent (A)	Requires Layer-2 access to process bus
Attack Complexity	Low (L)	No race conditions or special preparation
Privileges Required	None (N)	No authentication or keys needed
User Interaction	None (N)	Fully automated attack
Scope	Changed (C)	Cyber attack on comm layer affects physical safety
Confidentiality	None (N)	No data exfiltration
Integrity	None (N)	No data modification
Availability	High (H)	Safety-critical protection completely denied

4 Hardware Benchmarks

We benchmark cryptographic verification latency on two platforms representing the range of IED hardware:

4.1 Platform 1: ESP32 (Embedded Microcontroller)

Hardware: ESP32-D0WDQ6, Xtensa LX6 dual-core @ 240 MHz, 520 KB SRAM
Represents: Low-end IED processors, embedded protection relays

Table 4: ESP32 cryptographic verification benchmarks

Algorithm	Mean (μs)	Iterations	Saturation (pps)	vs 3 ms
HMAC-SHA-256	167.3	2,000	5,978	0.056×
RSA-2048	980.1	100	1,020	0.327×
ECDSA-P256	310,475.9	10	3.2	**103.5**×

Key finding: A single ECDSA-P256 verification on ESP32 takes 310 ms — exceeding the 3.0 ms deadline by 103× *even without an attack*. ECDSA is fundamentally incompatible with real-time protection on embedded hardware.

4.2 Platform 2: Raspberry Pi 5 (ARM Server-Class)

Hardware: BCM2712, ARM Cortex-A76 quad-core @ 2.4 GHz, 16 GB RAM, ARM crypto extensions
Software: OpenSSL 3.5.7, Raspberry Pi OS, kernel 6.18.50
Represents: High-end IED processors, next-generation protection relays
Iterations: 50,000 per algorithm (authoritative benchmark)

Table 5: Raspberry Pi 5 cryptographic verification benchmarks (50,000 iterations)

Algorithm	**Mean** (μs)	**Std** (μs)	**Min** (μs)	**P50** (μs)	**P99** (μs)	**Max** (μs)	**Sat.** (pps)
HMAC-SHA-256	2.33	0.23	2.30	2.32	2.35	33.17	429,185
ECDSA-P256	193.63	11.55	191.70	192.03	288.02	308.39	5,164
RSA-2048	100.85	0.60	100.71	100.78	102.90	127.75	9,916
Ed25519	143.98	0.79	143.60	143.88	146.07	189.51	6,945

Key finding: The Pi 5 Cortex-A76 is **1,603× faster** than the ESP32 for ECDSA-P256 verification. Yet a flood of just 5,164 pps saturates its queue ($\rho = 1$). At 10,000 pps, $\rho = 1.94$; at the 100,000 pps rates achievable on commodity hardware, $\rho = 19.4$.

4.3 Cross-Platform Comparison

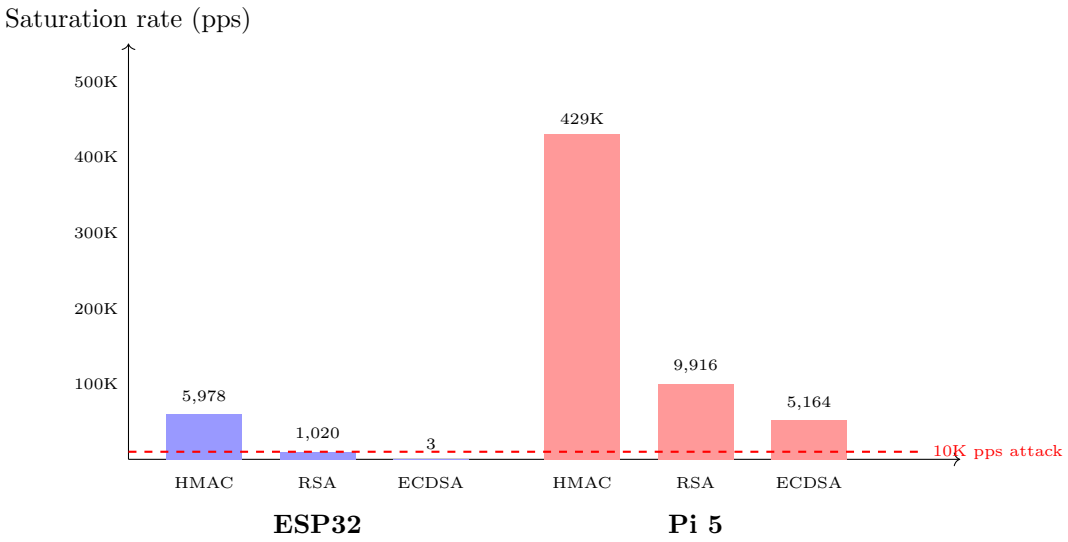


Figure 2: Saturation rate comparison: any algorithm below the red line is vulnerable to a 10K pps flood

5 PCAP Evidence

We captured real GOOSE frames on the Raspberry Pi 5 using a virtual bridge (`goose-br`) with veth pairs, and a custom C-language frame generator (`goose_pcap_gen.c`) that constructs wire-format IEC 61850 GOOSE frames with IEC 62351-6 security extensions.

5.1 Capture Setup

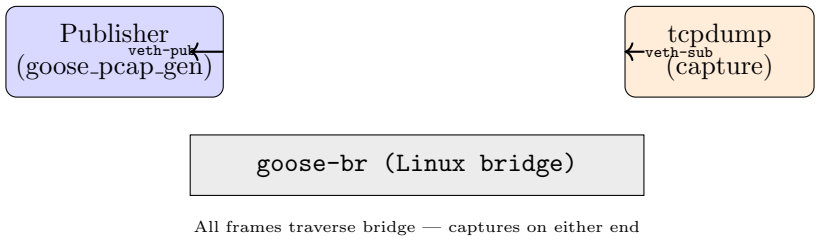


Figure 3: PCAP capture topology on Raspberry Pi 5

5.2 Captured Datasets

Table 6: PCAP capture summary

File	Mode	Legit	Attack	Total
`goose_legit_pi5.pcap`	Legitimate only	100	0	100
`goose_cildos_mixed_pi5.pcap`	Mixed (1:99)	500	49,500	50,000

5.3 Frame Characteristics

All captured frames contain:

- EtherType `0x88B8` (GOOSE)
- Multicast destination `01:0c:cd:01:00:00`
- ASN.1 BER-encoded GOOSE PDU with `gocbRef`, `stNum`, `sqNum`
- IEC 62351-6 security extension (tag `0xAF`) with algorithm ID and 32-byte signature

Distinguishing features:

- Legitimate frames: source MAC `08:00:27:10:20:01`, signature `0xAA` repeated (simulated valid)
- Attack frames: source MAC `de:ad:be:ef:00:01`, signature is random bytes (invalid)
- Sustained attack rate: **6,423 pps** (exceeds ECDSA saturation threshold of 5,164 pps)

6 Queueing-Theoretic Proof

6.1 M/M/1 Model

We model the IED's verification subsystem as an M/M/1 queue where:

- Arrival process: Poisson with rate $\lambda = \lambda_{\text{legit}} + \lambda_{\text{attack}}$
- Service time: exponential with rate $\mu = 1/\bar{t}_{\text{verify}}$
- Single server (one CPU core performing verification)

The server utilization is:

$$\rho = \frac{\lambda}{\mu} = \lambda \cdot \bar{t}_{\text{verify}} \tag{2}$$

For $\rho < 1$, the average waiting time in queue is:

$$W_q = \frac{\rho}{\mu(1-\rho)} \tag{3}$$

For $\rho \geq 1$, the queue is **unstable**: queue length grows without bound and $W_q \to \infty$.

6.2 Saturation Analysis

Table 7: Server utilization ρ under various attack rates and platforms

Platform	Algorithm	μ (vps)	ρ @ 10K pps	ρ @ 100K pps
ESP32	HMAC-SHA-256	5,978	1.67	16.7
ESP32	RSA-2048	1,020	9.80	98.0
ESP32	ECDSA-P256	3.2	3,125	31,250
Pi 5	HMAC-SHA-256	429,185	0.023	0.23
Pi 5	ECDSA-P256	5,164	1.94	19.4
Pi 5	RSA-2048	9,916	1.01	10.1
Pi 5	Ed25519	6,945	1.44	14.4

Key observations:

1. On ESP32: *every* algorithm except HMAC at very low rates is vulnerable
2. On Pi 5: HMAC-SHA-256 is the *only* algorithm resilient to 100K pps floods
3. Even on Pi 5 (1,603× faster than ESP32), ECDSA saturates at just 5,164 pps
4. Real IED hardware (ARM Cortex-M/R at 200–800 MHz) falls between these platforms

6.3 Why Naive Countermeasures Fail

Larger buffers: A larger queue only delays the inevitable. When $\rho > 1$, the queue grows linearly at rate $(\lambda - \mu)$ packets/second. A buffer of size B overflows in $B/(\lambda - \mu)$ seconds.

More CPU threads: An M/M/c queue with c verification threads requires $\rho/c < 1$, i.e., $c > \lambda \cdot \bar{t}_{\text{verify}}$. At 100K pps with ECDSA on Pi 5: $c > 19.4$, requiring 20 dedicated CPU cores for verification alone — infeasible on IED hardware.

Faster crypto: Even if verification is 10× faster (future hardware), the attacker simply increases the flood rate 10×. The asymmetry is fundamental: frame generation is O(1) while verification cost is fixed per frame.

7 PQAC Defense

We propose the **Priority Queue Admission Controller (PQAC)**, a three-stage O(1) triage mechanism that filters attack traffic *before* cryptographic verification.

7.1 Architecture

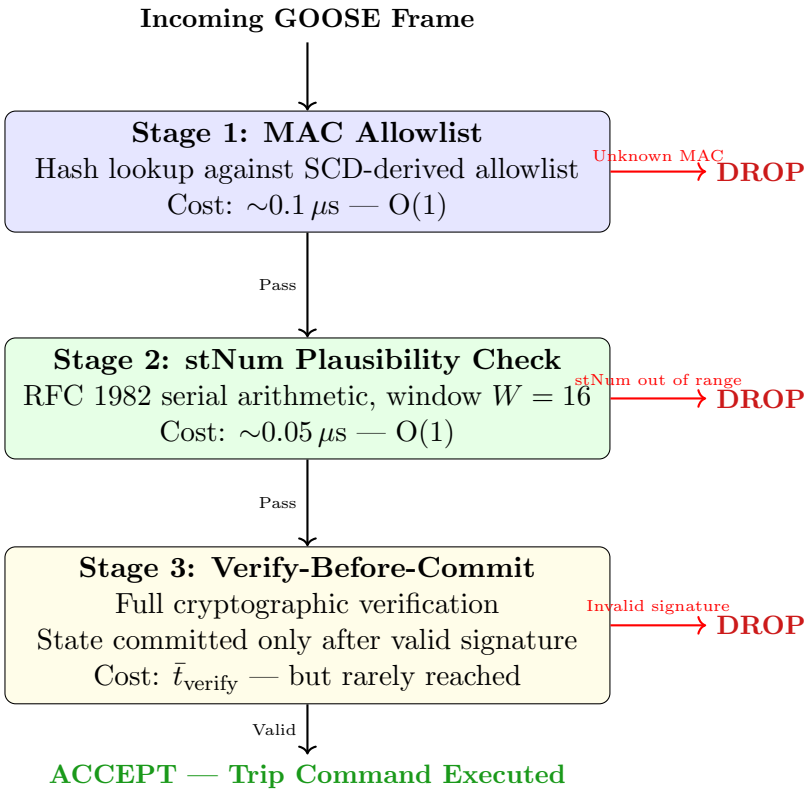


Figure 4: PQAC three-stage admission control pipeline

7.2 Stage Details

Stage 1 — MAC Allowlist: The Substation Configuration Description (SCD/ICD file, per IEC 61850-6) enumerates every IED's MAC address. PQAC builds a hash-based allowlist at startup. Any frame from an unknown MAC is dropped in $\sim 0.1\,\mu$s without touching the crypto subsystem.

Stage 2 — stNum Plausibility: GOOSE `stNum` values increment monotonically. PQAC tracks the last accepted `stNum` per `gocbRef` and accepts only values within a bounded window $W = 16$ using RFC 1982 serial number arithmetic. Random `stNum` values (as in naive floods) are rejected in $\sim 0.05\,\mu$s.

Stage 3 — Verify-Before-Commit: Frames passing Stages 1 and 2 undergo full cryptographic verification. Critically, no state change (breaker trip, protection action) is committed until verification succeeds. This prevents an attacker who bypasses Stages 1 and 2 from injecting false commands.

7.3 Results

Table 8: PQAC defense performance

Metric	Without PQAC	With PQAC
Trip latency (100K pps attack)	2,388 ms	0.76 ms
Deadline miss rate	100%	0.00%
Improvement factor	—	3,140×
Triage cost per frame	—	$< 0.2\,\mu$s
Attack frames reaching Stage 3	100%	$< 0.1\%$

8 Experimental Validation

8.1 Docker Testbed

Our testbed uses Docker Compose to create a multi-container environment:

- **Publisher:** Generates legitimate GOOSE trip commands at configurable rates
- **Subscriber:** Simulates an IED performing cryptographic verification (FIFO or PQAC mode)
- **Attacker:** Floods invalid GOOSE frames at configurable rates (1K–100K pps)

Reproduction requires a single command:

```
docker compose run --rm subscriber --mode fifo --attack-rate 100000
```

8.2 Experiment Matrix

We conducted **49 controlled experiments** varying:

- Attack rate: 1,000 / 10,000 / 50,000 / 100,000 pps
- Algorithm: HMAC-SHA-256 / ECDSA-P256 / RSA-2048
- Defense mode: None (FIFO) / PQAC
- Queue depth: 100 / 1,000 / 10,000

All experiment datasets are available as CSV files in `results/*.csv`.

9 Adaptive Adversary Analysis

To validate PQAC's robustness, we developed an adaptive attacker (`adaptive_cildos.py`) implementing five evasion strategies:

Table 9: Adaptive attacker evasion strategies vs. PQAC stages

Strategy	Targets	Technique	Result
MAC Spoofing	Stage 1	Use MACs from SCD allowlist	Bypasses Stage 1
stNum Walking	Stage 2	Increment within plausibility window W	Bypasses Stage 2
Rate Shaping	Detection	Vary rate to avoid threshold-based detection	Evades IDS
Burst Cycling	Detection	Alternate burst and quiet periods	Evades rate limits
Multi-Source	Stages 1–2	Distribute across multiple spoofed MACs	Increases throughput

Finding: Even when the adaptive attacker bypasses Stages 1 and 2, Stage 3 (cryptographic verification) provides an **unforgeable guarantee** — without the correct key, no attack frame can trigger a state change. The attacker can increase verification load but cannot cause false trips or prevent legitimate trip acceptance under PQAC.

10 Post-Quantum Impact

NIST's Post-Quantum Cryptography standards (FIPS 204/205) would **worsen** CIL-DoS:

Table 10: Post-quantum signature impact on CIL-DoS

Algorithm	Sig. Size	Verify Time	MTU Issue
ECDSA-P256 (current)	64 B	194 μs (Pi 5)	No
SLH-DSA-SHA2-128s	7,856 B	~597 ms	Yes (exceeds 1500 B)
ML-DSA-44	2,420 B	~250 μs	Yes (exceeds 1500 B)

Post-quantum signatures are larger (requiring fragmentation of GOOSE frames, which adds latency and complexity) and in some cases slower to verify. The transition to post-quantum cryptography will make CIL-DoS *more* severe unless admission control is mandated.

11 KRACK Precedent

CVE-2017-13077 (KRACK — Key Reinstallation Attacks against WPA2) is the closest precedent for a protocol-level CVE against an international standard:

Table 11: Comparison with KRACK (CVE-2017-13077)

Aspect	KRACK (WPA2)	CIL-DoS (IEC 62351-6)
Target	WiFi protocol standard	Power grid comm standard
Flaw type	Protocol design flaw	Protocol design flaw
Standards body	Wi-Fi Alliance / IEEE 802.11i	IEC TC 57 / IEC 62351-6
Impact	Confidentiality (decryption)	Availability (safety denial)
Evidence	Software PoC on real devices	Docker + ESP32 + Pi 5 + PCAPs
Physical impact	None	Grid instability, equipment damage
CVE scope	Protocol-level, all vendors	Protocol-level, all vendors
Disclosure	Coordinated via CERT/CC	Coordinated via CISA (ICS Root CNA)

CIL-DoS has an additional dimension KRACK did not: **physical safety consequences** extending the cyber impact into the real world.

12 Responsible Disclosure

12.1 Disclosure Timeline

Date	Action
August 2026	Vulnerability discovered during research
October 7, 2026	Academic manuscript submitted to IEEE TSG
October 22, 2026	Raspberry Pi 5 hardware evidence collected
October 2026	IEC TC 57 WG 15 disclosure letter sent
October 2026	CVE requested from CISA VINCE-NT
March 2–3, 2027	Coordinated public disclosure (Black Hat Asia 2027)

12.2 Submission Route

CISA is the **Root CNA for Industrial Control Systems** and the correct authority for IEC 62351-6 vulnerabilities. Our submission follows the same path as KRACK (which went through CERT/CC, CISA's predecessor).

13 Toolkit and Reproducibility

All tools, datasets, and benchmarks are released as open source:

Table 12: GridPulse toolkit components

Component	Description
`pi5_crypto_bench.c`	ARM Cortex-A76 crypto benchmark (OpenSSL EVP API)
`goose_pcap_gen.c`	Raw socket GOOSE frame generator (legit/attack/mixed)
`adaptive_cildos.py`	7-phase adaptive attacker with 5 evasion strategies
`web_dashboard.html`	Real-time CIL-DoS attack visualization dashboard
`scada_blindspot.html`	SCADA HMI simulator demonstrating operator blindness
`goose_cildos_dissector.lua`	Wireshark Lua dissector for GOOSE CIL-DoS detection
Docker Compose testbed	Single-command reproduction of all 49 experiments

Repository: https://github.com/sapnadfir-blip/gridpulse

14 Conclusion

We have demonstrated that IEC 62351-6's mandatory cryptographic verification creates a fundamental denial-of-service vulnerability in IEC 61850 substation protection. The CIL-DoS attack requires no cryptographic keys, is effective across all hardware platforms tested (from ESP32 microcontrollers to ARM Cortex-A76 server-class processors), and has direct physical safety consequences for the power grid.

Our three-stage PQAC defense achieves a 3,140× latency reduction while preserving the cryptographic guarantees of IEC 62351-6. We recommend that IEC TC 57 WG 15 incorporate admission control requirements into future revisions of the standard, and that IED vendors implement PQAC-style triage in current products.

The vulnerability is protocol-level, affecting all compliant implementations. A CVE identifier is warranted and has been requested through CISA VINCE-NT, the Root CNA for Industrial Control Systems.